Rapport de tests — Damascino Privilèges

Date d'exécution : 2026-09-28 · environnement : serveur de test unique (4 cœurs, 16 Go) hébergeant les 5 microservices, PostgreSQL, RabbitMQ, le site et le générateur de charge.

Synthèse

Campagne	Périmètre	Résultat
Tests unitaires	Règles métier, QR signés, import, verrouillage, sessions, sécurité, exports	**45 / 45 réussis**
Tests fonctionnels (bout en bout)	Site d'administration et application mobile, parcours complets dans un navigateur	**54 / 54 réussis**
Tests d'intégration	Échanges entre microservices via RabbitMQ, gateway, sessions, concurrence, panne du broker	**12 / 12 réussis**
Performance — charge nominale	100 bénéficiaires, 10 caisses, pic de 50 utilisateurs simultanés	**12 / 12 contrôles OK, 0 erreur**
Performance — stress	300 bénéficiaires, 20 caisses, pic de 150 utilisateurs simultanés	**12 / 12 contrôles OK, 0 erreur**
Contrôles statiques	ESLint, TypeScript (site et application)	**OK**

Anomalie détectée et corrigée pendant la campagne : 10 modifications simultanées d'une même fiche bénéficiaire provoquaient 4 erreurs serveur (500), un conflit de verrou optimiste non absorbé. Correctif : reprise automatique jusqu'à 6 fois avec une courte attente aléatoire, et réponse claire (409 « modifiée en même temps, réessayez ») si le conflit persiste. Test d'intégration ajouté ; 3 exécutions consécutives sans erreur.

1. Tests unitaires

`cd backend && mvn verify` : 45 tests, 0 échec. Règles d'avantage et éligibilité, calcul de la remise caisse, signature et expiration des QR codes, import Excel/CSV (doublons, formats), chiffrement des accès temporaires, recherche, bus de commandes (reprise sur conflit), filtrage des saisies (XSS), neutralisation des formules CSV, limitation des tentatives de connexion, politique d'accès par application, rapprochement des ventes.

2. Tests fonctionnels (bout en bout)

Playwright pilote un vrai navigateur : le site d'administration (ordinateur) et l'application mobile (téléphone Pixel 7), y compris le **scan par la caméra** avec une caméra simulée affichant le QR code.

Domaine	Scénarios	Réussis	Durée
Accès, authentification, rôles	8	8	14 s
Comptes (administration)	3	3	8 s
Bénéficiaires	1	1	6 s
Catégories	1	1	2 s
Import des listes, export des accès	1	1	6 s
Partenaires et règles	6	6	15 s
API caisse	7	7	16 s
Rapprochement caisse	2	2	13 s
Statistiques, journaux, exports	1	1	8 s
Site (installation, affichage mobile)	3	3	7 s

Domaine	Scénarios	Réussis	Durée
Sécurité (en-têtes, CSP, XSS, CSV)	5	5	12 s
Application — espace bénéficiaire	6	6	52 s
Application — remise en caisse assistée	2	2	6 s
Application — scanner du personnel	8	8	67 s
Total	**54**	**54**	**3.9 min**

3. Tests d'intégration

Suite `e2e/tests/integration-services.spec.ts` (API uniquement, à travers la gateway). Les temps indiqués sont les **délais de propagation mesurés** entre services.

Scénario	Résultat	Propagations mesurées
un bénéficiaire créé est propagé à identity, privilege et reporting, puis son activation revient au partenaire	✔	partner → identity (compte créé): 550 ms partner → reporting (autorisés): 26 ms identity → partner (compte activé): 442 ms identity → reporting (activés): 20 ms partner → privilege (QR disponible): 15 ms
un passage validé est projeté dans le reporting (montants, personnel, statistiques)	✔	privilege → reporting (passage): 857 ms privilege → reporting (statistiques): 16 ms
un refus est projeté dans le journal des refus avec son motif	✔	partner → privilege (désactivation): 443 ms privilege → reporting (refus): 432 ms
règle modifiée, partenaire désactivé puis réactivé : propagés au service privilèges	✔	partner → privilege (règle): 465 ms partner → privilege (partenaire inactif): 858 ms partner → privilege (réactivation): 848 ms
changement de téléphone : le nouvel identifiant fonctionne, l'ancien non	✔	partner → identity (identifiant): 1128 ms
les actions d'administration sont tracées dans le journal	✔	partner → reporting (journal): 17 ms
le rejeu des événements (republish) ne double aucun chiffre	✔	—
matrice des droits par rôle à travers la gateway	✔	—
jetons : rotation du jeton de rafraîchissement, réutilisation et déconnexion refusées	✔	—
session unique : le jeton de l'ancien téléphone est refusé par le service privilèges	✔	identity → privilege (session remplacée): 852 ms
modifications simultanées d'un même bénéficiaire : aucune erreur serveur, état final cohérent	✔	partner → identity (nom): 643 ms
RabbitMQ arrêté : les actions réussissent et les événements sont livrés à son retour (outbox)	✔	outbox → identity après retour du broker: 5136 ms

La résilience a été testée en arrêtant réellement RabbitMQ : la création d'un bénéficiaire réussit pendant la panne (événement conservé dans l'outbox), puis le compte devient utilisable quelques secondes après le redémarrage du broker, sans perte.

4. Tests de performance

Script `e2e/perf/load-test.mjs` : il crée ses propres données (partenaire, import de la liste, comptes de caisse), puis enchaîne les scénarios en passant par l'entrée publique (site, gateway, services), comme un vrai téléphone.

Charge nominale — 100 bénéficiaires, 10 caisses

Scénario	Requêtes	Débit (req/s)	p50	p95	p99	Erreurs
Import Excel/CSV de 100 bénéficiaires	1	0.4	2 698 ms	2 698 ms	2 698 ms	0.00 %
Première connexion + nouveau mot de passe	100	19.2	493 ms	742 ms	788 ms	0.00 %
Connexion bénéficiaire (mot de passe)	100	31.1	301 ms	443 ms	509 ms	0.00 %
Connexion personnel de caisse (PIN)	10	33.1	200 ms	301 ms	301 ms	0.00 %
Espace bénéficiaire (GET /privileges/me)	11719	585.4	32 ms	56 ms	73 ms	0.00 %
QR code du jour (POST /privileges/qr)	12427	620.4	31 ms	51 ms	63 ms	0.00 %
Pic : 50 utilisateurs simultanés sur /me	6411	638.9	77 ms	115 ms	136 ms	0.00 %
Admin : statistiques du tableau de bord	1697	169.3	28 ms	44 ms	55 ms	0.00 %
Admin : recherche de bénéficiaires	3107	310.5	15 ms	27 ms	38 ms	0.00 %
Passage en caisse complet (10 caisses en parallèle)	100	101.5	89 ms	147 ms	163 ms	0.00 %

Contrôle métier sous charge	Résultat
Tous les passages de la ruée en caisse sont confirmés	✔ 100/100
Un même QR présenté à 5 caisses simultanément : un seul passage	✔ 10/10 QR avec exactement 1 confirmation
Le reporting retrouve tous les passages	✔ 110/110 en 0.5 s

Stress — 300 bénéficiaires, 20 caisses

Scénario	Requêtes	Débit (req/s)	p50	p95	p99	Erreurs
Import Excel/CSV de 300 bénéficiaires	1	0.1	7 151 ms	7 151 ms	7 151 ms	0.00 %
Première connexion + nouveau mot de passe	300	19.9	488 ms	684 ms	745 ms	0.00 %
Connexion bénéficiaire (mot de passe)	300	33.6	284 ms	417 ms	534 ms	0.00 %
Connexion personnel de caisse (PIN)	20	36.8	225 ms	307 ms	340 ms	0.00 %
Espace bénéficiaire (GET /privileges/me)	12288	613.8	30 ms	53 ms	65 ms	0.00 %
QR code du jour (POST /privileges/qr)	12083	603.9	31 ms	53 ms	65 ms	0.00 %
Pic : 150 utilisateurs simultanés sur /me	7257	707.7	209 ms	295 ms	363 ms	0.00 %
Admin : statistiques du tableau de bord	1754	175.2	27 ms	43 ms	56 ms	0.00 %
Admin : recherche de bénéficiaires	3473	347.1	13 ms	24 ms	34 ms	0.00 %
Passage en caisse complet (20 caisses en parallèle)	300	136.9	136 ms	208 ms	255 ms	0.00 %

Contrôle métier sous charge	Résultat
Tous les passages de la ruée en caisse sont confirmés	✔ 300/300
Un même QR présenté à 5 caisses simultanément : un seul passage	✔ 10/10 QR avec exactement 1 confirmation
Le reporting retrouve tous les passages	✔ 310/310 en 1.5 s

Lecture des résultats

- **Parcours en caisse** : moins de 0,25 s au 95e centile pour QR + vérification + confirmation, avec 20 caisses en parallèle ; aucun passage perdu ni compté deux fois.
- **Application bénéficiaire** : 600 à 700 requêtes par seconde soutenues ; avec 150 utilisateurs simultanés, 95 % des réponses en moins de 0,3 s. Pour Damascino (quelques centaines de passages par jour), la marge est très large.
- **Connexion** : environ 30 connexions par seconde, limité volontairement par le hachage bcrypt des mots de passe (protection contre le vol de mots de passe).
- **Cohérence** : le reporting retrouve 100 % des passages en 0,5 à 1,5 s après la fin de la charge.
- **Point d'attention — import de listes** : ≈ 24 ms par ligne (génération et chiffrement des mots de passe temporaires), soit ≈ 2 min pour 5 000 lignes, proche du délai maximal de 120 s du proxy. Recommandation : importer les très grandes listes en plusieurs fichiers (3 000 lignes au plus), ou passer l'import en tâche de fond.
- Les mesures ont été faites sur une seule machine qui héberge aussi le générateur de charge : un serveur de production dédié donnera des résultats égaux ou meilleurs.

Relancer les tests

```
cd backend && mvn verify                                    # unitaires
docker compose up -d --build                                # stack complète
cd e2e && npm ci && npm run build:app                       # export web de l'application
(tests)
npx playwright test                                         # fonctionnels + intégration
E2E_BROKER_STOP="docker compose stop rabbitmq" E2E_BROKER_START="docker compose start rabbitmq"
\
  npx playwright test --project=integration                 # + test de panne de RabbitMQ
npm run perf                                                # performance (PERF_USERS,
PERF_TILLS, PERF_PEAK…)
```